



Human-related ICT Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
4. Requirements	9
4.1. Requirements	9
5. Roles and Responsibilities	16
5.1. Creator	16
5.2. Guideline Owner	16
6. Appendix	17
6.1. Contact Information	17
6.2. Document History	17
6.3. Related Written Rules	17
6.4. Abbreviations	18

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The Human-related ICT Management Guideline (hereinafter "Guideline") establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other controls addressing poor administration and human error risks.	4.3
Protect	4. Check background verification on all candidates to become personnel should be carried out prior to joining the organization and on an ongoing basis	4.3

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

	taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.	
Protect	5. Define employment contractual agreements which state the personnel's and the organization's responsibilities for ICT security.	4.3
Learn and evolve	1. Develop, implement, and maintain an ICT risk awareness program including trainings as a compulsory module in staff training schemes.	4.7
Communicate	2. Formalize a disciplinary process and communicate it to take actions against personnel and other relevant interested parties who have committed a violation to this policy.	4.8
Communicate	3. Define, enforce, and communicate ICT responsibilities and duties that remain valid after termination or change of employment and communicate them to relevant personnel and other interested parties.	4.8

Table 1: Minimum Requirements

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; Chief Compliance Officer Area; or any other area that owns Human-related ICT Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Human-related ICT Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
ICT Risk Oversight	To oversee and ensure secure and efficient use of ICT resources.
ICT Operational Management	To implement and maintain technical measures that are outlined in the Guideline and ensure compliance.
Business Management	To implement and manage human-related solutions and controls and to integrate ICT Guidelines into employee onboarding and trainings.

Table 3: Target groups

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirements

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Levels of flexibility

With respect to requirements and criteria, the following terms are used to define the level of flexibility, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirements

ID: 1 (version 2.0)	Screening and verification procedures
1 DOR.ICT.HRM.SVP.001	Procedures for screening and verifying candidates before employment must be defined, implemented, managed, and controlled.
1.1 DOR.ICT.HRM.SVP.002	Procedures for screening and verification must be documented and reviewed at least every 12 months. The procedures must at least consider: - The candidate's curriculum vitae and criminal records - Claimed academic and professional qualifications - Independent identity verification - External references for employees with executive employment contracts (for Level 5 and above) Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.1

ID: 2 (version 2.0)	Contractual obligations regarding information security
2 DOR.ICT.HRM.CON.001	Contractual obligations must consider the organization's demand on information security to ensure adherence and to prevent information leakage.
2.1 DOR.ICT.HRM.CON.002	The contractual obligations for personnel must take into consideration the organization's information security Policies and Guidelines and their adherence to these. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.2
2.2 DOR.ICT.HRM.CON.003	Confidentiality or non-disclosure agreements must be signed prior to being given access to information and other associated assets. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.2

ID: 3 (version 2.0)	General requirements for ICT security awareness program and Digital operational resilience (DOR) training
3 DOR.ICT.HRM.AWE.001	It must be ensured that the ICT security awareness program and DOR training fulfil the general requirements in terms of target group, content and necessary adjustments.
3.1 DOR.ICT.HRM.AWE.002	The following must apply to all employees of legal entities and ICT third-party service providers who either use or have access to the IT and non-IT Assets of the legal entity: Asset-Types: Business Process Key References: DORA RTS RMF A.19.b.i
3.1.1 DOR.ICT.HRM.AWE.003	They must be aware of information security requirements derived from relevant security Policies, Guidelines and Procedures and comply with them in their daily work. Asset-Types: Business Process Key References: DORA RTS RMF A.19.b.i
3.1.2 DOR.ICT.HRM.AWE.004	They must be aware of reporting channels for the detection of anomalous behavior, including reporting channels for whistleblowing. Asset-Types: Business Process Key References: DORA RTS RMF A.19.b.ii
3.2 DOR.ICT.HRM.AWE.005	ICT security awareness program and DOR training that cover ICT security obligations and raise awareness of ICT risks among all employees must be defined. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3
3.3 DOR.ICT.HRM.AWE.006	The ICT security awareness program and DOR training must include at least the following information: Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3
3.3.1 DOR.ICT.HRM.AWE.007	Personal responsibility for own actions and omissions and general responsibilities to protect IT and non-IT Assets. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3
3.3.2 DOR.ICT.HRM.AWE.008	Fundamental information security obligations (such as reporting ICT-related incidents), generally applicable security measures and information on behavior when security-relevant events occur. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3
3.3.3 DOR.ICT.HRM.AWE.009	Prevalent and emerging cyber threats and risks. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3
3.4 DOR.ICT.HRM.AWE.010	The ICT security awareness program and DOR training must be developed and provided for at least the following target groups:

	Asset-Types: Business Process Key References: DORA 2022/2554 A.13.6
3.4.1 DOR.ICT.HRM.AWE.011	All employees of the legal entity. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.6
3.4.2 DOR.ICT.HRM.AWE.012	The management body of the legal entity. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.6
3.4.3 DOR.ICT.HRM.AWE.013	Third-party service providers must be included in the ICT security awareness program and DOR training where appropriate and applicable, when: - an ICT-related incident for which an Incident Management Meeting (IMM) or Incident Classification Meeting (ICM) has been conducted, and an Incident Statement has been created, where: - o the incident was caused by a third party due to a lack of awareness or negligent/unintentional behavior; or - o the prescribed remediation measures include awareness or training activities; or - contractual obligations regarding ICT security awareness training have not been fulfilled, and the third party is unable to provide a plan with appropriate mitigating actions. Asset-Types: Business Process, Supplier Key References: DORA 2022/2554 A.13.6
3.5 DOR.ICT.HRM.AWE.014	The ICT security awareness program, AI awareness and literacy program where applicable and possible, and DOR training must be provided, reviewed and updated at least once every 12 months and must be kept consistent with the Policies and Guidelines. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.3

ID: 4 (version 2.0)	Digital operational resilience (DOR) training
4 DOR.ICT.HRM.DTR.001	It must be ensured that structured training is provided, ranging from medium to the highest level of complexity, which builds DOR capabilities by equipping both specialists and all employees, including the management body, with technical and other relevant skills to adequately deal with ICT disruptions and other relevant ICT-related challenges.
4.1 DOR.ICT.HRM.DTR.002	The level of complexity of the DOR training must be tailored to the functions of the internal employees, management body or employees of third-party service providers. Asset-Types: Business Process Key References: /
4.2 DOR.ICT.HRM.DTR.003	The following must apply to employees for whom it is relevant by virtue of their role or responsibilities:

	Asset-Types: Information, Business Process, Supplier Key References: § 8a (1) BSIG 68
4.2.1 DOR.ICT.HRM.DTR.004	Regarding KRITIS services, regular and documented instruction must be provided regarding the secure configuration and operation of the IT applications and infrastructure required for the critical service, including mobile devices. Asset-Types: Information, Business Process, Supplier Key References: § 8a (1) BSIG 68
4.2.2 DOR.ICT.HRM.DTR.005	Where applicable, regular awareness and training requirements must be established for specific roles, such as users of information systems and services, legal entity IT operations and Information Security 1st LoD, which require adequate and technical knowledge of ICT risks and security measures. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 A.6.3
4.2.3 DOR.ICT.HRM.DTR.006	Additional needs for training or awareness measures, e.g., for employees with privileged access, for secure coding, or against phishing attacks, should be considered. Asset-Types: Information, Business Process, Supplier Key References: ISO 27001:2022 Cor 202203 C.7.3

ID: 5 (version 2.0)	AI Awareness and Literacy Program
5 DOR.ICT.RAI.ALP.001	A comprehensive and role-specific AI literacy program must be established, maintained, and continuously improved to ensure that all personnel involved in the AI system lifecycle possess the necessary competence, awareness, and understanding of AI-related risks, ethics, and operational responsibilities.
	Governance on educational program
5.1 DOR.ICT.RAI.ALP.002	An AI literacy/educational program must be established and documented. Asset-Types: Business Process Key References: Article 4 EU AI Act
5.2 DOR.ICT.RAI.ALP.004	Roles and responsibilities related to AI literacy/education must be assigned, documented, and communicated across the organization. Asset-Types: Business Process Key References: ISO 42001 A.3.2
5.3 DOR.ICT.RAI.ALP.005	The AI literacy/educational program should reference other relevant organizational policies and be available to interested parties, as appropriate. Asset-Types: Business Process Key References: Article 4 EU AI Act
	Competence and Qualification

5.4 DOR.ICT.RAI.ALP.008	Security education AI Risk & Threat awareness for technical roles for data scientists and development teams on AI threat awareness, including attacks on models, must should be established. Asset-Types: Business Process Key References: Article 4 EU AI Act
	Awareness and Training
5.5 DOR.ICT.RAI.ALP.009	All engineers, including data scientists, should attend appropriate training before developing AI systems. Asset-Types: Business Process Key References: Article 4 EU AI Act
5.6 DOR.ICT.RAI.ALP.010	Training programs should be tailored to roles and include topics such as AI fundamentals, ethical considerations, data privacy and security, model development, human-centered design, and AI system applications. Asset-Types: Business Process Key References: Article 4 EU AI Act

ID: 6 (version 2.0)	Compliance with ICT risk awareness and training
6 DOR.ICT.HRM.COM.001	It must be ensured that the ICT security awareness program, relevant AI awareness and literacy training where applicable, and DOR training are performed, monitored and reported.
6.1 DOR.ICT.HRM.COM.002	ICT risk awareness, AI awareness and literacy training where required by role and where possible, and DOR training must be completed at least on an annual basis, by the end of each calendar year and compliance must be monitored. For certain programs, such as DOR training, adherence to year-end completion schedule will apply to training cycle commencing in the upcoming calendar year. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3
6.2 DOR.ICT.HRM.COM.003	Standard reporting, for AI awareness and literacy training where applicable and possible, regarding training participation must be available. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.6.3, ISO 42001 7.3

ID: 7 (version 2.0)	Disciplinary process
7 DOR.ICT.HRM.DIS.001	Compliance of employees with legal entity's information security requirements must be enforced and the disciplinary consequences must be made transparent. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.6.4

ID: 8 (version 2.0)	Termination of employment
8 DOR.ICT.HRM.TER.001	A process must be designed, implemented, managed, and controlled to ensure that all assets are returned to the organization and access rights are deactivated and revoked upon termination of employment. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: DORA RTS RMF A.19.b.iii

ID: 9 (version 2.0)	Change of employment
9 DOR.ICT.HRM.COE.001	It must be ensured that access rights are adjusted accordingly in the event of changes to employment.
9.1 DOR.ICT.HRM.COE.002	The following Information Security requirements relevant for changes of employment must be fulfilled: Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: ISO 27001:2022 Cor 202203 A.6.5
9.1.1 DOR.ICT.HRM.COE.003	Access rights for employees must be aligned with their positions and must be reviewed and adjusted according to the control requirements in the Identity and Access Management Guideline. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: ISO 27001:2022 Cor 202203 A.6.5
9.1.2 DOR.ICT.HRM.COE.004	For employees that: - Change the company - Change the position (for example due to work content or employment status changes like from student to employee) - Change their contract (from fixed term to permanent) in combination with a company/position change - Perform a Career Track Change (in combination with a company/position change) - Are promoted in combination with a company/position change access rights to primary and secondary assets, excluding the birth right roles, must be reviewed and adjusted (if necessary).

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Building, Room, Datacenter Key References: ISO 27001:2022 Cor 202203 A.6.5
--	--

5. Roles and Responsibilities

5.1. Creator

The creator of the Human-related ICT Management Guideline is the **ICT Risk Governance & Advisory** Unit (Specialist).

The creator of Human-related ICT Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Human-related ICT Management Guideline is Head of **ICT Risk Governance & Advisory** Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Human-related ICT Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact **ICT Risk Governance & Advisory** in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual guideline review with material change

Coordination before publication

Version	Date	Task	Name
2.0	01.04.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	08.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	08.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	ICT HR Procedure

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
